

GDPR INTRO

Sammen kommer vi #foran**digitalt**

DEL 1 – De viktigste begreber



Hvad er GDPR? Lovgivningen

- EU General Data Protection Regulation – gældende fra 18. maj 2018
 - 88 siders forordning (dvs gældende lov) for alle EU lande (ikke kun direktiv)
 - *Regulation (EU) 2016/679 of the European Parliament and of the Council of 27 April 2016 on the protection of natural persons with regard to the processing of personal data and on the free movement of such data*
- Suppleret med Dansk Databeskyttelseslov – vedtaget 17. maj 2018
 - Præciserer diverse ting, fx at grænsen for at være “barn” er 15 år i Danmark (GDPR siger “16 år, evt. lavere”) og hvordan danske CPR numre skal behandles
 - *Lov om supplerende bestemmelser til forordning om beskyttelse af fysiske personer i forbindelse med behandling af personoplysninger og om fri udveksling af sådanne oplysninger (databeskyttelsesloven)*



Hvad er personoplysninger?

- En personoplysning (a.k.a. persondata, personhenførbare oplysning, ...) er *enhver form for information, der kan henføres til en bestemt person, også selv om personen kun kan identificeres, hvis oplysningen kombineres med andre oplysninger.*
- Personoplysninger kan for eksempel være navne, telefonnumre, emailadresser, personnumre, registreringsnumre, billeder, fingeraftryk, stemmeoptagelser, citater, lægejournaler, biologisk materiale, ...
 - *Oplysninger, som praksis gør det muligt at identificere en person ud fra oplysningerne eller i kombination med andre.*



Fire slags personoplysninger

1. “Almindelige” personoplysninger (ikke-følsomme persondata)
2. Særlige kategorier af personoplysninger (følsomme persondata)
 - A.k.a. “Personfølsomme” oplysninger (misvisende)
3. Fortrolige oplysninger, herunder CPR numre, oplysninger om straffedomme og lovovertrædelser eller tilknyttede sikkerhedsforanstaltninger
 - Betragt som følsomme oplysninger
4. Oplysninger om børn under 15 år
 - Ekstra sikkerhed
 - Kræver *altid* samtykke fra indehaveren af forældremyndigheden over barnet.



Følsomme personoplysninger

1. Race og etnisk oprindelse
2. Politisk, religiøs eller filosofisk overbevisninger
3. Fagforeningsmæssige tilhørsforhold
4. Genetiske data (DNA)
5. Biometriske data (fx fingeraftryk, øjenscan, stemmeoptagelser)
 - Kun følsomt hvis det behandles med henblik på entydig identifikation
6. Helbredsoplysninger
 - *Hvad* man fejler er følsomt, “*at* man er syg” er ikke følsomt
7. Seksuelle forhold eller seksuel orientering



Hvad er “behandling” er persondata?

- »Behandling« dækker over en lang række handlinger, der udføres med personoplysninger, herunder med manuelle eller automatiske metoder.
- Det omfatter indsamling, registrering, organisering, systematisering, opbevaring, tilpasning eller ændring, genfinding, søgning, brug, videregivelse ved transmission, formidling eller enhver anden form for overladelse, sammenstilling eller samkøring, begrænsning, sletning eller tilintetgørelse af personoplysninger.



Principper for behandling af persondata

- a) lovlighed, rimelighed og gennemsigtighed (hjemmel og oplysning)
- b) formålsbegrænsning (kun til oplyste formål)
- c) dataminimering (ikke mere data end nødvendigt for formål)
- d) rigtighed (data skal være korrekte)
- e) opbevaringsbegrænsning (ikke længere end nødvendigt)
- f) integritet og fortrolighed (pas på data)

“Hjemmel” – hvornår må du behandle?

- Behandling af personoplysninger **er kun lovlig, hvis en af følgende:**
 - a) Den registrerede har givet sit **samtykke** til behandlingen.
 - b) Behandlingen er nødvendig af hensyn til en **kontrakt med den registrerede**.
 - c) Behandlingen er nødvendig af hensyn til en retlig forpligtelse, fx bogføringsloven
 - d) Behandlingen er nødvendig af hensyn til den registrerede eller en anden fysisk persons vitale interesser, fx hvis den registrerede ikke selv kan give samtykke
 - e) Behandling er nødvendig af hensyn til en opgave i samfundets interesse eller offentlig myndighedsudøvelse (kun brugbart for off. organisationer)
 - f) Behandlingen er nødvendig af hensyn til en **legitim interesse**, som ikke overgås af den registreredes interesser eller rettigheder:
interesseafvejningsreglen



Hjemmel – følsomme oplysninger mv

- Det er som udgangspunkt **forbudt** at behandle **følsomme** personoplysninger, men der er undtagelser til dette forbud:
 - hvis den registrerede tydeligvis selv har **offentliggjort** oplysningerne på forhånd
 - hvis den registrerede har givet **udtrykkeligt samtykke** til behandling
 - ... andre mindre væsentlige undtagelser ...
- Private må behandle oplysninger om **strafbare forhold**, hvis den registrerede har givet sit **udtrykkelige samtykke** hertil.
- Behandling af personoplysninger i systemer benyttet af børn under 15 år: kun hvis **samtykke fra indehaveren af forældremyndigheden**



Samtykke som hjemmel

- Samtykket skal være **frivilligt, specifikt, informeret og utvetydigt**
 - Skal forelægges på en måde, som klart kan skelnes fra evt. andre forhold, i en letforståelig og lettilgængelig form og i et klart og enkelt sprog
 - Må ikke gives stiltiende eller være underforstået
 - Bundet til det **formål**, som den registrerede er blevet oplyst om, da samtykket blev indhentet. Hvis flere formål skal der kunne tages stilling individuelt.
 - Samtykke **kan trækkes tilbage!** Retten hertil skal oplyses
 - Tilbagekaldelse af samtykke vedrører kun den fremtidige behandling af den registreredes data
 - Ofte fordel at referere til oplysningsskema
- **Krav**, at den dataansvarlige kan **påvise**, at den registrerede har givet samtykke til behandlingen af sine personoplysninger
- **Udtrykkeligt** samtykke (følsomme data): skriftligt anbefales!



GDPR “Roller” - Hvad er “Dataansvar”

- Den dataansvarlige er den, der bestemmer **hvorfor** (med hvilket **formål**) og **hvordan** (med hvilke **hjælpemidler** / hvilke **metoder**), personoplysninger bliver behandlet.
- Det er ikke afgørende hvem der “ejer” data eller hvem der indsamler data



Hvilken rolle har vi i behandlingen?

- Vi (virksomheden som organisation) kan have én eller flere roller i de behandlinge(r) af persondata, som vi er involveret i:
- **Selvstændig dataansvarlig**
 - **VI** definerer formål med, og metoder til, behandlingen af persondata. Fx HR data.
- **Databehandler** for en anden organisation
 - En anden organisation (fx kunde) definerer formålet med behandlingen og giver os **instruks** i hvordan behandlingen skal foregå
- **Fælles dataansvarlig** med anden/andre organisation(er)
 - Vi aftaler i fællesskab med andre organisationer hvad formål med behandling er, og hvad vi hver især skal gøre – fx i fælles udviklingsprojekt i et konsortium



Hvis vi er dataansvarlig

- **VI** skal sikre, at der er **hjemmel** til behandling
- **VI** skal føre en **fortegnelse** over hvilke typer data vi behandler for hvilke typer registrerede
- **VI** skal sørge for at overholde **oplysningspligten** overfor de registrerede, så de gøres opmærksomme på
 - **At** vi behandler personhenførbare data om dem
 - **Hvorfor** vi gør det (**formål**)
 - **Hvordan** vi behandler data om dem (**metode**)
 - Med hvilken **hjemmel** vi gør det
 - Deres **rettigheder** jf. GDPR
- **VI** skal kunne dokumentere at GDPR principperne for behandling (herunder risiko baseret sikkerhed) overholdes
- (**VI** skal lave forudgående **konsekvensanalyse**, hvis behandlingen sandsynligvis vil indebære en høj risiko for fysiske personers rettigheder og frihedsrettigheder)

Hvis vi er databehandler for anden org

- Den anden organisation er ansvarlig for hjemmel, oplysningspligt etc.
 - Vi kan dog godt være hyret til at varetage fx indsamling af samtykker og udlevering af oplysningsskemaer på vegne af dem
- Der SKAL laves en **databehandleraftale** hvor den anden organisation (den dataansvarlige) laver instruks til os om hvad vi skal gøre, hvilke sikkerhedsforanstaltninger vi skal etablere mv.
 - Er på 20+ sider ☹
 - Databehandleraftalen er den anden organisations (fx kundens) ansvar. Men ofte os der skriver den for dem “som om vi var dem”.
 - Det er ulovligt for os at lave behandlingen uden at aftalen er på plads – vi skal afvise dette!



Hvis vi er fælles dataansvarlige

- Hvis vi er fælles dataansvarlige med andre organisationer:
- Der SKAL laves en “**aftale om fælles dataansvar**” (også kaldet “delt dataansvar”).
 - “Kun” 6-7 sider 😊.
 - Beskriver hvordan “fordelingen” af dataansvar, herunder sikring af hjemmel og håndtering af oplysningspligten, håndteres indbyrdes mellem de fælles dataansvarlige
 - Fx baseret på hvem der indsamler bestemte dele af data (nemtest at de giver oplysninger om behandlingen)



Hvis vi bruger andre databehandlere

- Uanset om vi er dataansvarlige (evt. fælles) eller databehandlere for en anden organisation, så kan vi komme ud for at vi sender persondata videre til andre organisationer som en del af at opfylde vores eget (eller kundens) formål med behandlingen, fx
 - **SurveyXact**, som vi beder om at indsamle spørgeskemaer
 - Eller “bare” det at vi placerer data på **Microsofts** OneDrive platform
- Her skal **VI** sørge for at der er databehandleraftale med underdatabehandleren
 - Ofte er kun “Standardvilkår” mulige – se leverandørernes databehandleraftaler



Hvis vi videregiver persondata

- Hvis vi videregiver persondata til anden organisation med henblik på at den anden organisation kan bruge data til en behandling med et andet formål, så skal vi sikre at den dataansvarlige
 - Har oplyst de registrerede om denne videregivelse til andet formål
 - Har sikret at der er hjemmel til denne videregivelse
- Ikke det samme, som hvis vi bruger underdatabehandler til opfyldelse af det primære formål
 - Ex: Vi driver en webshop og behandler kundernes persondata for at håndtere deres køb, kontooplysninger og forsendelsesadresser. Men vi videregiver også deres kontaktdata til en sponsor virksomhed mhp at de kan kontakte dem omkring salg af noget andet

Overførsler til andre lande

- Hvis vi overfører persondata til behandling i andre lande (enten til underdatabehandlere eller videregivelse til andre formål) så skal vi sikre for at det lovligt at overføre persondata til disse lande.
- Følgende lande er lovlige at overføre til:
 - **Alle EU lande**
 - De tre EØS lande: **Norge**, Island og Liechtenstein
 - Følgende “sikre tredjelande”: Andorra, Argentina, Guernsey, Isle of Man, Israel, Jersey, New Zealand, Schweiz, **Storbritannien**, Sydkorea, Uruguay
 - Sikre tredjelande (under bestemte betingelser): Canada, Færøerne, Japan, **USA** (modtagere selv-certificeret under [EU-U.S. Data Privacy Framework](#))
- Usikre lande (herunder Grønland!) kræver ekstra hjemmel.
 - Udtrykkeligt samtykke og kontrakt med den registrerede er mulighed (undtagelsesvis)

Behandlingssikkerhed (Artikel 32)

1. *Under hensyntagen til det aktuelle tekniske niveau, implementeringsomkostningerne og den pågældende behandlings karakter, omfang, sammenhæng og formål samt risiciene af varierende sandsynlighed og alvor for fysiske personers rettigheder og frihedsrettigheder gennemfører den dataansvarlige og databehandleren passende tekniske og organisatoriske foranstaltninger for at sikre et sikkerhedsniveau, der passer til disse risici, herunder bl.a. alt efter hvad der er relevant:*
- a) *pseudonymisering og kryptering af personoplysninger*
- b) *evne til at sikre vedvarende fortrolighed, integritet, tilgængelighed og robusthed af behandlingssystemer og –tjenester*
- c) *evne til rettidigt at genoprette tilgængeligheden af og adgangen til personoplysninger i tilfælde af en fysisk eller teknisk hændelse*
- d) *en procedure for regelmæssig afprøvning, vurdering og evaluering af effektiviteten af de tekniske og organisatoriske foranstaltninger til sikring af behandlingssikkerhed.*
2. *Ved vurderingen af, hvilket sikkerhedsniveau der er passende, tages der navnlig hensyn til de risici, som behandling udgør, navnlig ved hændelig eller ulovlig tilintetgørelse, tab, ændring, uautoriseret videregivelse af eller adgang til person oplysninger, der er transmitteret, opbevaret eller på anden måde behandlet.*



Risikobaseret tilgang (ISO27001 principper)



Risikobaseret sikkerhed

- I GDPR det er risikoen og konsekvenser for de registrerede (og ikke din virksomheds økonomi og renommé).
- Datatilsynet har generel vejledning om risikovurdering (incl. Podcast)
 1. Vurder trusler, sandsynlighed herfor og konsekvenser for de registrerede vedrørende fortrolighed, integritet og tilgængelighed (CIA).
 2. Implementer tekniske og organisatoriske foranstaltninger til at mitigere (nedbringe) uacceptable risici
- Mere letvægts model i deres vejledning om tilsyn med leverandører, kan bruges til hurtig initial vurdering

Datatilsynets simple risikoscore

A. Hvor mange personer:

- < 1.000: **1 point**
- 1.000 – 10.000: **2 point**
- >10.000: **3 point**

B. Følsomme oplysninger:

- Ja: **3 point**

C. Fortrolige oplysninger:

- Ja: **2 point**

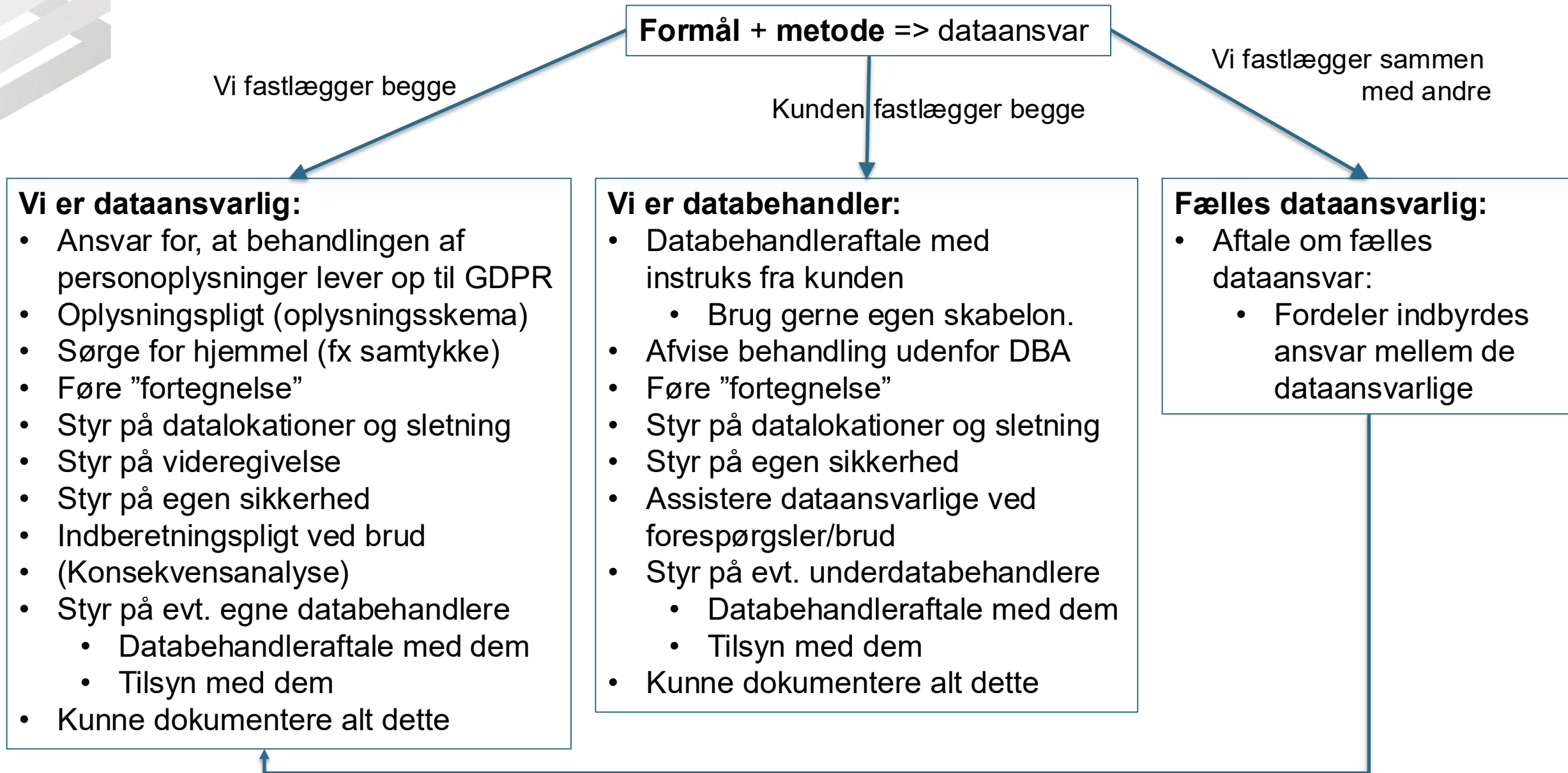
D. Særlige behandlinger:

- Ja: **2 point**

Samlet score: A + B + C + D

- 1 - 2 point: Meget lav risiko, standard sikkerhed sikkert nok
- 3 - 4 point: Lav risiko: enkle ekstra foranstaltninger kan være nødvendige
- 4 - 6 point: Mellem risiko: ekstra foranstaltninger er sandsynligvis nødvendige
- 7-10 point: Høj risiko: ekstra mitigerende foranstaltninger skal gennemføres

GDPR Oversigt



DEL 2 – GDPR i praksis



Alexandra projekt praksis: GDPR Skema

- Projekt stamdata og kort beskrivelse af behandlingen herunder formålet
- 5 Spørgsmål:
 1. Typer af persondata
 2. Rolle(r): databehandler og/eller (evt. fælles) dataansvarlig?
 3. Videregives data? Hvad er flowet?
 4. Fortegnelse: Detaljer om hver "klump" af data vi behandler

Case-skitse:

App aftestning for Dating.dk

- Din virksomhed har udviklet en ny Smartphone App og backend til Dating.dk
- Der skal nu gennemføres et aftestningsforløb af den nye App
- Dating.dk har skaffet 100 personer, som har meldt sig som frivillige testere i 3 måneder.
- Disse 100 testere logger ind i vores system og bruger det (med fuld funktionalitet) i de 3 måneder
- Herudover er der en håndfuld administratorer og supportere fra Dating.dk som kan logge ind i systemet

Brainstorm

- Skitser selv videre på casen
 - Hvad kan brugerne i appen?
 - Hvilke oplysninger giver brugerne som input?
 - Hvad gør appen med det data brugerne giver dem?
 - Evt skitser systemer og dataflow
- Hvad tror i man skal overveje angående GDPR?

GDPR Spørgsmål – kategorier og typer

1. Behandles der "persondata" eller bare data?
 - Er data anonymiseret/pseudonymiseret?
2. Hvilke kategorier af "registrerede" er der tale om?
3. Er det "mange" personer?
4. Hvilke typer af persondata er der tale om?
 - Er der "almindelige" persondata?
 - Er der "følsomme" persondata?
 - Er der "fortrolige persondata"?
5. Er det de samme typer persondata for alle kategorier af registrerede?

GDPR opgave – organisationsroller

- Er din virksomhed databehandler for Dating.dk for persondata?
 - Hvis JA: Hvad skal Dating.dk og din virksomhed sørge for?
- Er din virksomhed selvstændig dataansvarlig for persondata?
 - Hvis JA: Hvad skal din virksomhed sørge for?
- I begge tilfælde: inddrager vi andre organisationer i databehandlingen?

GDPR opgave - overførsler

- Bruger vi databehandlere til at gennemføre formålet med persondata-behandlingen?
- Overfører vi persondata til andre organisationer med henblik på et andet formål
- Overfører vi persondata til andre lande?
 - Er det EU/EØS Lande
 - Er det "sikre" eller "usikre" tredjelande

GDPR opgave - Fortegnelse

- Saml nu et skema, som for hver "klump" af data beskriver
 - Formål med din virksomheds behandling af dette data
 - Hjemmel for behandlingen
 - Kategorier af registrerede og typer af persondata
 - Gerne (specifikke) lokationer for data
 - Andre organisationer, som persondata gives videre til (incl. andre databehandlere)
 - Overføres til "usikre tredjelande"?
 - Slettefrister
 - Sikkerhedsforanstaltninger (kommer vi tilbage til i ISO27001)
 - Andre relevante dokumenter (databehandleraftale, oplysningsskemaer, samtykker mv)

Sikker transmission og lagring

Hvordan gør du i forhold til dataen?

- Hvis filen er 10mb?
- Hvis filen er 1tb?
- Hvis filen skal sendes fra server til server?
- Hvis filen skal sendes fra person til person?

Hvordan gør du i forhold til adgang til dataen?

- Hvordan håndterer du adgangskontrol?
- Hvordan håndterer du logging?

Udgangspunkt

